

Phishing Incident Report

1. Executive Summary

An external phishing campaign was detected targeting sonyundefinedralph@tsacad.com. The attacker impersonated the Microsoft Security Team to induce panic and trick the recipient to click a malicious link. Investigation confirmed that the email originated from a compromised third-party domain in Spain and redirected to a known malicious redirect.

Status: Resolved

Severity: High

Category: Phishing/Credential Harvesting

2. Detection & Analysis

A. Email IOCs

Artifacts	Value	Analysis
Header: From	Microsoft Security Team <info@libreriacies.es>	The display name is spoofed; the actual sender domain is a Spanish bookstore
Link	https[:]//tinyurl[.]com/ypu5kfts	Use of a URL shortener to bypass basic link filtering

⏪ Reply

⏪ Reply All

➡ Forward

➡ Forward



Subject: Unusual Login Activity Detected

From: Microsoft Security Team <info@libreriacies.es>

10:27 AM ★ ⏪ ⏩ ⋮

To: sonyundefinedralph@tsacad.com

Dear User,

We detected unusual login activity on your email account from a new device located outside your usual region.

To prevent temporary suspension of your account, please verify your identity immediately by clicking the link below:

<https://tinyurl.com/ypu5kfts>

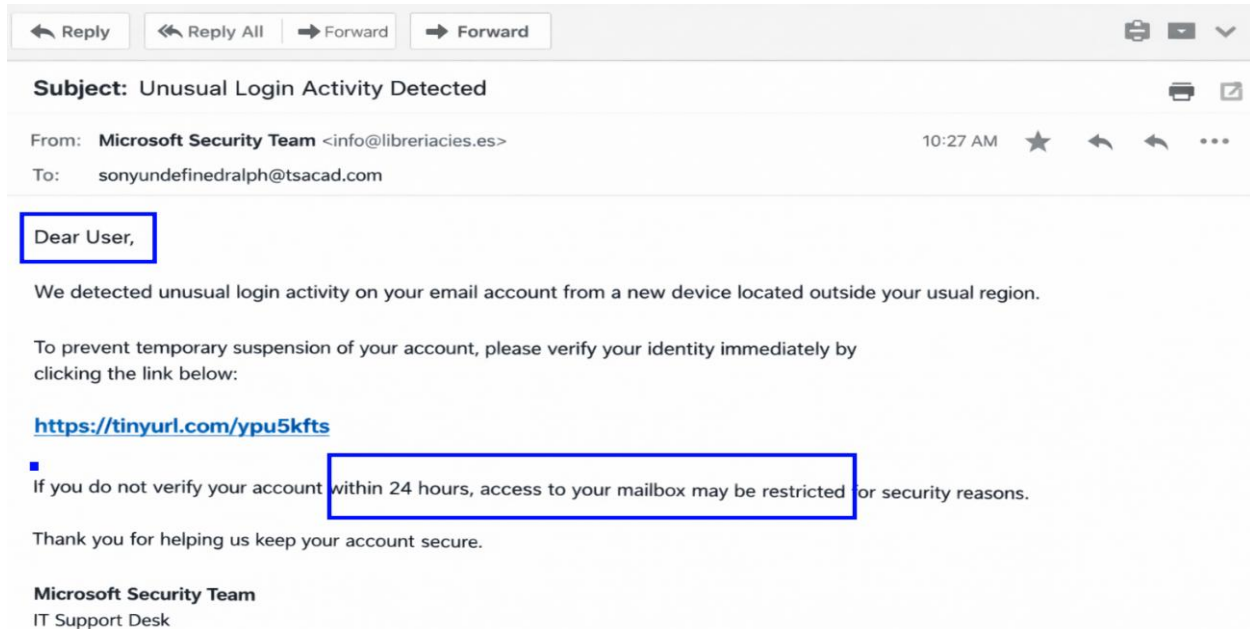
If you do not verify your account within 24 hours, access to your mailbox may be restricted for security reasons.

Thank you for helping us keep your account secure.

Microsoft Security Team
IT Support Desk

B. Behavioral IOCs

- **Social Engineering:** The attacker uses Urgency ("within 24 hours") and Fear ("access... may be restricted") to bypass the user's critical thinking.
- **Generic Greeting:** The use of "Dear User" instead of a specific name indicates mass-mailing.



C. Network IOCs

- **Whois** lookup for libreriacies.es showed the domain is hosted via Siapi Networks in Spain. Since the domain itself belongs to a legitimate bookstore, it is likely that a legitimate account was compromised to send this campaign.
- **MXToolbox** revealed "No DMARC record found" and "DMARC policy not enabled", allowing unauthorized senders to use the domain with minimal resistance.
- **Checkshorturl** resolved the short URL (https://tinyurl.com/ypu5kfts) to x-egamb.com. **Urlscan.io** identified x-egamb.com as a crypto scam landing page.

Whois Record for Libreriacies.es

— Domain Profile

Registrar Status	taken
Name Servers	NS34.TREVENQUE.ES (has 3,014 domains) SERLOGAL.ARNOIA.COM (has 2 domains)
IP Address	217.18.163.139 - 85 other sites hosted on this server
IP Location	 - Granada - Granada - Siapi Networks
ASN	 AS42220 SIAPI-AS TREVENQUE SISTEMAS DE INFORMACION S.L., ES (registered Jan 16, 2007)
Hosting History	1 change on 2 unique name servers over 6 years

Whois Record (last updated on 2026-01-23)

```
% NOTE: The registry for this domain name does not publish ownership
% records (whois records) in the standard format. This data
% represents the most likely status of the domain based on
% information provided by the Internet's domain name servers (DNS).

domain: libreriacies.es
status: taken
nameserver: ns34.trevenque.es
nameserver: serlogal.arnoaia.com

% For more information, please visit http://www.nic.es/
```

SuperTool Beta9

libreriacies.es

MX Lookup

mx:libreriacies.es

Find Problems

Solve Email Delivery Problems

mx

Pref	Hostname	IP Address	TTL	
10	mail.libreriacies.es	217.18.161.43 TREVENQUE SISTEMAS DE INFORMACION S.L. (AS42220)	5 min	Blacklist Check SMTP Test

Test	Result	
✗ DMARC Record Published	No DMARC Record found	More Info
✗ DMARC Policy Not Enabled	It is recommended to use a quarantine or reject policy. To enable BIMI, it is required to have one of these at 100%.	More Info
✓ DNS Record Published	DNS Record found	

dns lookup

dns check

dmARC lookup

spf lookup

dns propagation

Reported by serlogal.arnoaia.com on 1/23/2026 at 11:04:13 AM (UTC -6), just for you.

Transcript

Short URL

<https://tinyurl.com/ypu5kfts>

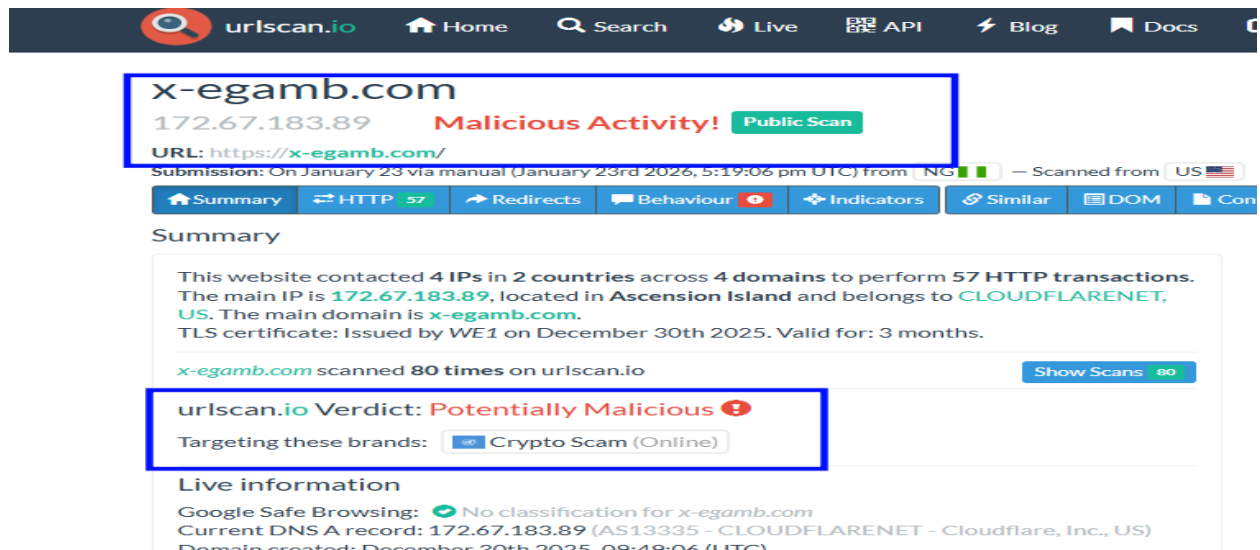
Long URL

<https://x-egamb.com/>

Code

301

Screenshot

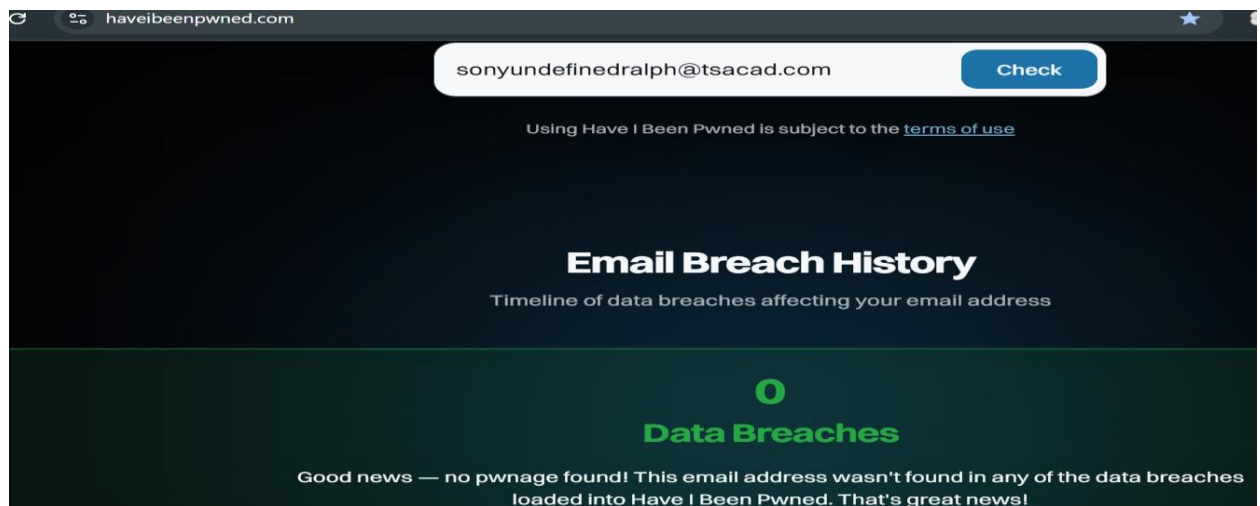


The screenshot shows the urlscan.io interface for a scan of **x-egamb.com**. The domain is highlighted with a blue box. The IP address **172.67.183.89** is shown, along with a red warning "Malicious Activity!" and a green "Public Scan" button. The URL is **https://x-egamb.com/**. The submission details indicate it was scanned on January 23rd, 2026, from NG (Netherlands) to US (United States). The summary section states that the website contacted 4 IPs in 2 countries across 4 domains to perform 57 HTTP transactions. The main IP is 172.67.183.89, located in Ascension Island and belongs to CLOUDFLARENET, US. The TLS certificate was issued by WE1 on December 30th, 2025, and is valid for 3 months. The domain x-egamb.com was scanned 80 times on urlscan.io. The verdict is "Potentially Malicious" with a red exclamation mark icon. It is targeting the brand "Crypto Scam (Online)". Live information includes Google Safe Browsing (No classification), Current DNS A record (172.67.183.89), and Domain created (December 30th, 2025).

D. Account exposure

A search on **Have I Been Pwned** was conducted for the recipient **sonyundefinedralph@tsacad.com**

- The email has not been involved in any known data breaches; this suggests the user may have been targeted through a mass-mailing list.



The screenshot shows the Have I Been Pwned website. The email address **sonyundefinedralph@tsacad.com** is entered in the search bar, and the "Check" button is visible. Below the search bar, it says "Using Have I Been Pwned is subject to the [terms of use](#)". The main heading is "Email Breach History" with the subtitle "Timeline of data breaches affecting your email address". The results show "0 Data Breaches" in green. At the bottom, it says "Good news — no pwnage found! This email address wasn't found in any of the data breaches loaded into Have I Been Pwned. That's great news!"

3. Containment

- Blocked the sender's IP address 217.18.161.43 (as shown by mxtoolbox) at the perimeter firewall.
- Added the malicious domain x-egamb.com and the TinyURL path to the organization's DNS sinkhole or web filter.

4. Eradication & Recovery

- Deleted all instances of this email from the mail server (Search & Purge) to prevent other users from clicking the link.
- Reset credentials for any user who interacted with the link.
- Monitor the targeted email account for:
 - unusual login patterns
 - creation of new inbox rules (often used by attackers to hide further activity).

5. Post-Incident Activity (Lessons Learned)

Root Cause:

Exploitation of a poorly configured third-party domain to bypass spam filters.

Improvement:

Implement Brand Protection tools to alert if external domains are masquerading as "Microsoft Support".

User Training:

Use this specific template for a simulated phishing exercise to train employees on identifying mismatched sender addresses and suspicious links.

Final Verdict

Classification: True Positive

The incident is confirmed as a Malicious Phishing attempt designed for credential harvesting.